

ENUMGRID

An honesty-disciplined, unprivileged-first network enumeration platform with a grounded LLM triage copilot

Santhakumar Parivallal

Dissertation defense · 2026 · engineering + measurement contribution

Every number is produced by a reproducible harness — no fabricated data.

The problem: tools launder uncertainty

A version-string guess and a confirmed exploit are shown as the same thing

VERSION GUESS

"Apache 2.4.49 → CVE-2021-41773" — inferred from a banner. A back-ported distro build makes this a confident false positive.

CONFIRMED EXPLOIT

A probe actually fired and the bug reproduced. Same visual weight in most tools — the reader cannot tell these apart.

And with an LLM in the loop, it gets worse

- Asked "what is exploitable here?", a fluent model will invent a plausible CVE id that was never in the scan.
- For a security tool, an invented finding is categorically worse than a missing one — a missed detail is recoverable; a fabricated CVE that sends an analyst down the wrong path is not.
- Yet scanners report coverage ("N vulns found") and stay silent on their false-positive and hallucination behaviour.

Thesis

**Treat "no fabrication" as a first-class,
measurable property of a scanner.**

Quantify and bound the tool's own over-claiming — for the deterministic CVE matcher AND the LLM copilot — instead of hiding it behind a single blended verdict.

Three defensible claims

Not algorithmic novelty — measured discipline

1

Honesty as a property

The matcher scores precision 1.00 / recall 1.00 (0 false positives) on a 33-case adversarial corpus; the copilot fabricates 0 CVEs across 5 runs.

2

Unprivileged fidelity

A four-signal (TTL + OUI + hostname + mDNS) discovery/OS fusion recalls 0.99 ± 0.02 of hosts vs 0.53 ± 0.93 for unprivileged nmap -sn — without root.

3

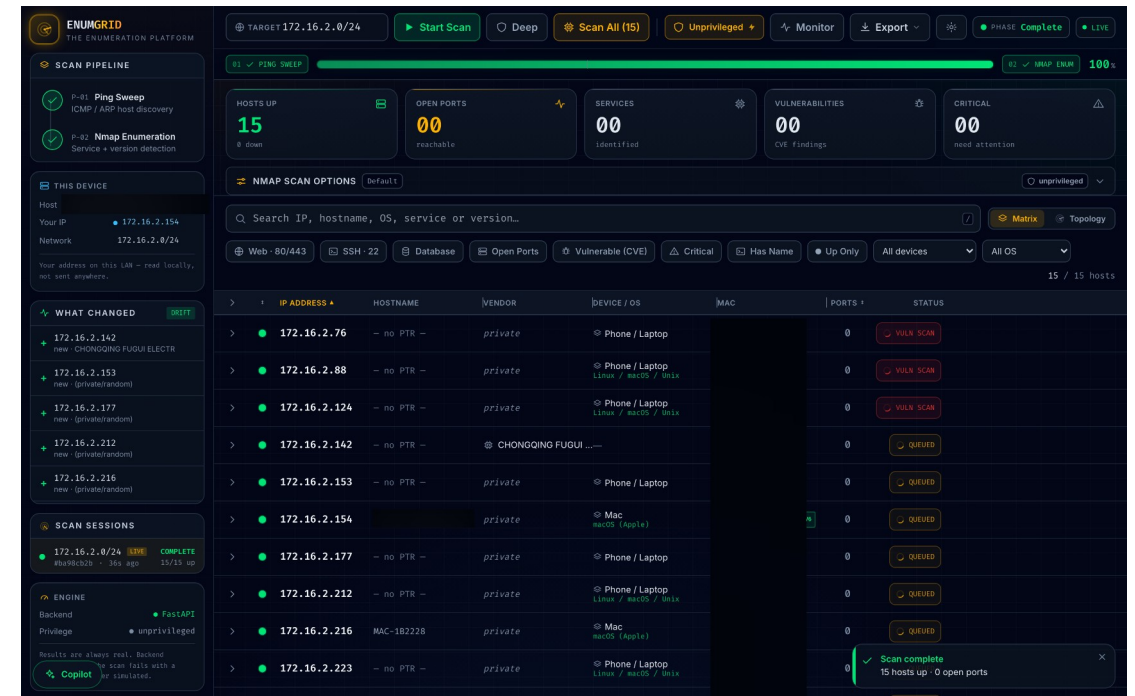
Grounded LLM copilot

Scan-grounded triage with a structural hallucination guard: real CVE ids into the context, a deterministic check on the way out. Grounding 1.000 ± 0.000 .

System design

Two-tier: single-file CLI + FastAPI/React, same engine, unprivileged-first

- Two phases: multi-method host discovery (ICMP/ARP/TCP), then nmap service/version enumeration, streamed over SSE.
- Four-signal unprivileged OS fusion — TTL + IEEE OUI + hostname + mDNS model — recovers fidelity without raw sockets.
- Privilege auto-adaptation: root-only nmap flags rewritten to safe equivalents; elevation holds the sudo password in memory only.
- Degrades to "Unknown" when signals disagree — never a guess.



Completed scan — 15/15 hosts, OS fusion, drift panel (hostname / MACs redacted for publication).

The honesty discipline — four mechanisms

What makes "no fabrication" measurable rather than a slogan

1 Confidence banding

confirmed (probed, $\text{conf} \geq 7$) vs version (inferred) — scored per band, so "high-confidence is more accurate" is measured.

2 Unknown over guessing

unresolved OS / vendor / version is labelled Unknown; no CVE for a version-less banner or untabled product.

3 Never-simulated data

no mock/demo mode in the evidence path; a failed scan says so instead of fabricating hosts.

4 Provenance

every scan carries a manifest; golden-file tests fix the parser→model→report pipeline byte-for-byte.

Evaluation methodology

Sound method; the honest limits are scale, not design

- Ground truth: exact on the pinned 9-host docker testbed; union-of-tools proxy (an upper bound) on real LANs.
- Closed-world scoring on the CVE corpus: any extra id is a false positive, any missing id a false negative.
- Uncertainty everywhere: Wilson 95% CIs; cross-environment macro-average (each network = one sample); multi-run CIs for the LLM.
- Same code paths as the product — the harnesses call `scanner._service_scan`, `vulndb.lookup_offline_cves`, `cve.parse_nvd`.
- Two layers: pure, unit-tested scoring (runs in CI, no Docker/network) + operator-run live runners.

2

environments (1 real LAN + 1 testbed)

178

CI-tested scoring tests, no Docker

Result: unprivileged discovery

Four-signal fusion vs an unprivileged ping sweep, pooled across two environments

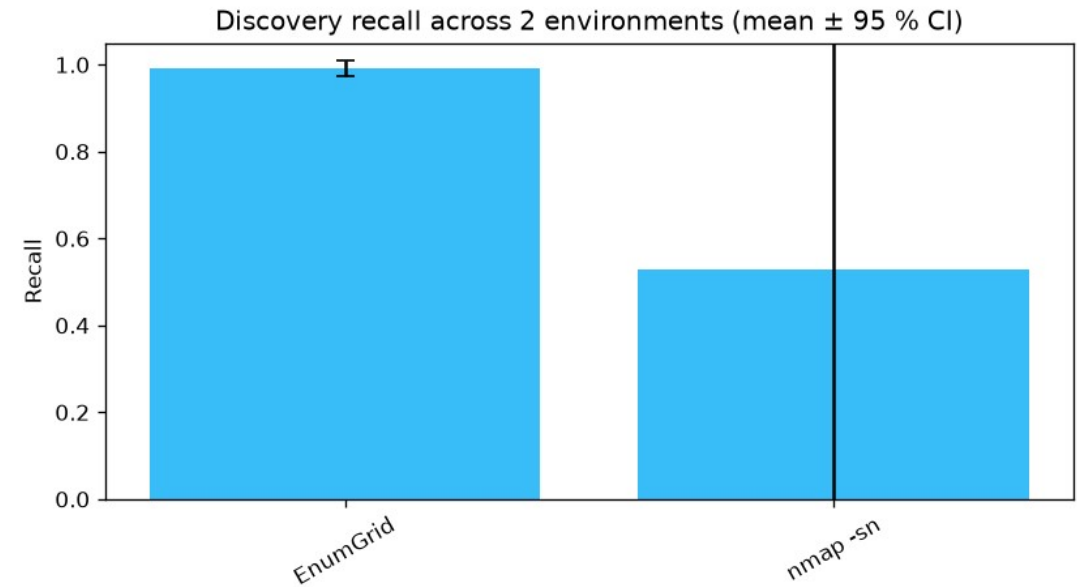
0.99

EnumGrid recall (± 0.02)

0.53

nmap -sn recall (± 0.93)

nmap -sn's huge CI is the honest headline: 0.06 on the ICMP-filtered LAN, 1.00 on the clean testbed — environment-dependent. EnumGrid is consistent. $n = 2$ is small and reported as such.



Cross-environment discovery recall (mean $\pm$ 95% CI, $n = 2$).

Result: service / port / version detection

9-host pinned testbed, through the product's own scan path

1.00 / 1.00

ports P / R (0 FP)

0.89

service accuracy (8/9)

0.83

version accuracy (5/6)

3/3

planted-CVE recall

Confidence banding predicts its own error

- High-confidence band ($\text{conf} \geq 7$, $n = 8$): service accuracy 1.00. Low band ($n = 1$): service 0.00 — and that single low-confidence detection is the single miss.
- 56 unexpected CVEs on the rolling images are surfaced for review, never scored as false positives — a rolling image's full CVE set is unknowable a priori.

Result: CVE matching — precision corpus

Attach the right CVE to the right version, and never a wrong one

1.00

precision (17/17)

1.00

recall — 0 false positives

33 adversarial cases: version boundaries (2.4.49 yes, 2.4.51 no), substring & magic-version collisions, a RHEL backport. Wilson 95% CI [0.816, 1.000]; CI-gated.

A real bug the corpus caught

The matcher's substring keyword match let "httpd" match inside "lighttpd" — so a patched lighttpd was flagged with Apache's path-traversal CVE. A genuine false positive.

Fixed with whole-token matching (vulndb._kw_hit) and locked by a regression test. This is the value of a precision corpus — it turns "we think it's accurate" into "here is the bug proving the test works."

Result: the primary live-NVD path — and its failure

Measured against the real NVD feed; the harness surfaced its own miss

8/8

documented-CVE recall

7/7

version-scoping precision

0 truncation losses from the CVSS top-N cap.

Finding — surfaced, not hidden

- First run scored 7/8. The harness attributed the miss to absence (NVD returned 0 rows), not truncation.
- Root cause: NVD indexes the vsftpd 2.3.4 backdoor under vendor vsftpd_project; nmap emits vsftpd — a CPE-dictionary drift.
- Why it matters: the live-NVD layer alone has recall gaps where the two dictionaries disagree — which is exactly why ENUMGRID also runs the in-scan vulners NSE and an offline table, both of which recall it independently.

Compared to what? Two schools of detection

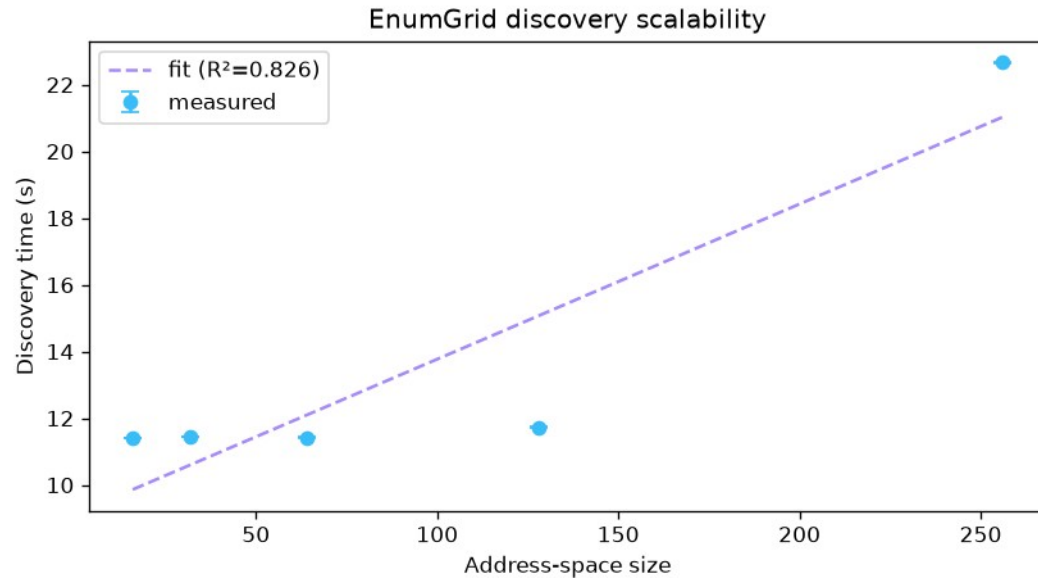
Three detectors, same planted hosts — the tradeoff, on real hosts

Tool	School	Recall	Unexpected
nmap-vulners	version-match	1.00 (3/3)	133
EnumGrid	version-match (conservative)	0.67 (2/3)	13
Nuclei	active-PoC	0.00 (0/3)	0

- Version-match maximises recall but is noisy — nmap-vulners gets 3/3 at 10× the false alarms (133 vs 13). EnumGrid trades a little recall for far less noise.
- Active-PoC (Nuclei) fires nothing: the vanilla images expose the version but not the exploitable config — high precision, config-dependent recall.
- EnumGrid's own recall varied 2/3 ↔ 3/3 across runs — real live-scan nondeterminism, which is why we measure run-to-run stability.

Scalability & the grounded copilot

Timing fit on the authorised /24, and a structural hallucination guard



Discovery time: 46.5 ms/address + 9.1 s overhead, $R^2 = 0.83$ (/28 → /24).

Copilot grounding

1.000 ± 0.000

grounding across 5 runs — 0 fabricated CVEs

- Structural, not sampled: real CVE ids into the context, a deterministic guard on the way out.
- The only variance is coverage (recall) — the residual failure of a grounded model is silence, never invention.
- A --self-test proves grounding collapses to 0 on a fabricated reply, so the metric can't be gamed.

Threats to validity & honest positioning

Named before a reviewer can

What the evidence supports

- Discovery significantly out-recalls an unprivileged ping sweep.
- Detection has no false positives on a known testbed.
- The offline matcher is whole-token precise; copilot hallucination is bounded and measured.

What it does NOT yet support

- A general "1.00 across arbitrary real networks" — $n = 2$, one synthetic.
- Superiority over a mature vuln scanner (Nessus/OpenVAS).
- Scalability beyond a /24; small, author-curated corpora.
- This is an integration + measurement contribution, not a new algorithm — a strong dissertation / workshop paper.

Contributions & what's next

Scaffolded, honest — the rest needs real inputs, not fabrication

Contributions

- A two-tier, unprivileged-first enumeration platform.
- An honesty discipline made measurable.
- A reproducible measurement suite through the product's own code paths.
- Two findings only an honest harness surfaces (CPE drift; the lighttpd FP).

Turnkey, awaiting real inputs

- Several distinct authorised networks → tighten the cross-env CI (runbook ready).
- A held-out, independently-sampled CVE corpus (template + protocol ready).
- OpenVAS/Nessus baselines (report-file adapters ready).
- A pre-registered analyst user study (protocol ready — must be run, never simulated).

The contribution is the discipline — and its measurement.

- precision 1.00 / recall 1.00 on an adversarial CVE corpus — the one false positive it found is fixed and regression-locked
- 0 fabricated CVEs across five copilot runs
- 0.99 ± 0.02 unprivileged discovery recall vs a highly environment-dependent 0.53 ± 0.93 baseline
- a primary live-NVD path at 1.00 recall — with its one real failure mode surfaced and attributed

Thank you.